THREAT INTELLIGENCE ADVISORY ? Wordpress Defacement campaign
==========

Distribution: TLP:AMBER Analyst handoff Confidence: HIGH (IOCs are defanged)
Affected host: wordpress-prod-01 Suspected origin IP: 198.51.100.40

1. EXECUTIVE SUMMARY
An external actor executed a multi-stage post-compromise sequence. Endpoint alerting covered only part of it; several persistence and anti-forensic actions were silent. Map every on-disk finding to the ATT&CK techniques below and flag which are NOT in the SAS alert feed.

2. ATT&CK TECHNIQUE MAPPING (MITRE ATT&CK Enterprise)
  T1190 Exploit Public-Facing Application [initial-access] step 1: WordPress plugin RCE (CVE-2022-1609)
  T1505.003 Web Shell [persistence] step 2: PHP webshell planted
  T1491.001 Internal Defacement [impact] step 3: site defacement
  T1053.003 Cron [execution] step 4: cron persistence
  T1505.003 Web Shell [persistence] step 5: .htaccess redirect

3. RELEVANT VULNERABILITIES (source: NVD, US-Gov public domain)
  CVE-2022-1609 CVSS 9.8 (CRITICAL) v3.1 CWE=CWE-94
    The School Management WordPress plugin before 9.9.7 contains an obfuscated backdoor injected in it’s license checking code that registers a REST API handler, allowing an unauthenticated attacker to execute arbitrary PHP code on the site.
    ref: https://wpscan.com/vulnerability/e2d546c9-85b6-47a4-b951-781b9ae5d0f2/

4. INDICATORS OF COMPROMISE (defanged)
  ip 198.51.100.40
  c2 update-wordpress[.]example[.]cn
  pool stratum+tcp[:]//xmr[.]wordpress[.]evil[:]3333
  wallet 4A0000000000000000001b88b8daaa21

Attribution: MITRE ATT&CK(R) (C) The MITRE Corporation, CC BY 4.0. CVE/CVSS from the U.S. National Vulnerability Database (public domain).